Práctica. Caso SOC integral: investiga tu propio ataque

Nombre y apellidos: _____

Miércoles 25 de noviembre de 2026 · IC · 4 horas · trabajo individual

Esto es lo más parecido a un día de trabajo en un SOC que vais a hacer en el curso. La semana pasada pasaron tres cosas con vuestra web: el jueves la atacasteis vosotros mismos (y apuntasteis la hora de cada prueba), y el lunes la bastionasteis. Hoy os sentáis del lado del defensor: vais a investigar en vuestro Wazuh ese ataque de principio a fin, reconstruir qué pasó y cuándo, ver qué detectó vuestro SOC y qué se le escapó, y escribir el informe del caso. Y como sabéis exactamente qué hicisteis (lo tenéis en vuestra bitácora de Hacking Ético), por una vez tenéis la "verdad del terreno" para comprobar si vuestro SOC decía la verdad.

1. Qué vas a aprender hoy

1. Investigar un incidente completo con las alertas de tu Wazuh.
2. Reconstruir una línea temporal cruzando el SOC con la bitácora del atacante.
3. Medir la cobertura de detección: qué se vio y qué no, y por qué.
4. Evaluar si una medida de defensa (el bastionado) habría parado cada ataque.
5. Escribir un informe de incidente con las fases detección, impacto, contención, erradicación y lecciones.

2. Lo que necesitas

Tu Wazuh en marcha, con las reglas de miweb (100200-100212) que cargaste el 18 de noviembre. Tu agente activo en el Ubuntu. Y, muy importante, **tu bitácora de Hacking Ético del 19**, con la hora de cada prueba.

Si el 19 no llegaste a atacar la web (porque te faltó montar algo), no pasa nada: en el apartado 10 tienes un plan para generar hoy mismo el ataque y seguir la práctica igual.

Descarga de la web del curso (IC, Prácticas) el material de hoy: `consultas-soc.md` y `plantilla-caso-soc.md`.

3. Comprueba tu SOC (10 minutos)

```
cd ~/wazuh-docker/single-node
docker compose ps
docker compose exec -T wazuh.manager /var/ossec/bin/agent_control -l
```

El manager tiene que estar arriba y tu agente, `Active`. Si tu Wazuh no arranca, lee el apartado 10 antes de seguir.

4. Saca las alertas del periodo del ataque (25 minutos)

Vuelca las alertas recientes a un fichero de trabajo y quédate con las de tu web. En `consultas-soc.md` tienes las recetas; la primera saca todo a `~/ic/caso.json`:

```
mkdir -p ~/ic
cd ~/wazuh-docker/single-node
docker compose exec -T wazuh.manager tail -n 5000
/var/ossec/logs/alerts/alerts.json > ~/ic/caso.json
```

Mira cuántas veces saltó cada regla, para hacerte una idea del ataque antes de entrar al detalle:

```
jq -rc 'select(.rule.groups | index("miweb")) | .rule.id + " " +
.rule.description' \
  ~/ic/caso.json | sort | uniq -c | sort -rn
```

Vas a reconocer el perfil: muchos `login_fallido`, una de fuerza bruta, la de login correcto tras la ráfaga, la de la inyección, la del acceso a datos ajenos... Cada una es una pieza del jueves.

5. Reconstruye la línea temporal (45 minutos)

Esta es la parte central. Con la receta de línea temporal de `consultas-soc.md` saca las alertas de tu web ordenadas por hora:

```
jq -rc 'select(.rule.groups | index("miweb"))
  | [.timestamp, .data.srcip // .data.ip // "-", .rule.id, .rule.level,
.rule.description]
  | @tsv' ~/ic/caso.json | sort
```

Ahora abre tu bitácora del 19 al lado y rellena la tabla de la plantilla (apartado 3). Para cada momento: la hora que vio el SOC, la que apuntaste tú, qué regla saltó y a qué fase del ataque corresponde. Fíjate en que la hora del SOC está en **UTC** y la tuya seguramente en hora local: apunta las dos y explica la diferencia. Reconstruir bien esto es lo que, en un caso real, permite contar la historia del incidente a alguien que no estaba.

6. ¿Qué vio el SOC y qué se le escapó? (35 minutos)

Aquí usas tu ventaja: sabes exactamente qué hiciste. Rellena la tabla de cobertura (apartado 4 de la plantilla): para cada prueba del jueves (enumeración de rutas, enumeración de usuarios, fuerza bruta, inyección SQL, IDOR, XSS), mira si generó alguna alerta y cuál.

Vas a descubrir que **no todo deja la misma huella**. Algunas pruebas encienden una alerta clara; otras pasan casi desapercibidas o solo aparecen en el registro de nginx sin una regla que las marque. Eso no es un fallo tuyo: es la realidad de un SOC. Lo importante es **saber qué no estás viendo**. Para cada prueba que no generó alerta, escribe por qué (¿no hay regla para eso?, ¿la petición no llegó a la aplicación?, ¿la hiciste tan despacio que no disparó la frecuencia?).

7. Impacto y nivel (20 minutos)

Mira las alertas de nivel alto (la receta de `jq` con `level>=12`). La más grave de este ataque es la de **login correcto tras una ráfaga de fallos**: significa que una cuenta quedó comprometida. Apunta en el apartado 5 qué cuenta y qué pudo hacer el atacante con ella (acuérdate de la inyección SQL: pudo leer la tabla de usuarios entera). Clasifica el incidente: ¿fue solo un intento o hubo acceso real?

8. ¿Lo habría parado el bastionado? (25 minutos)

El lunes bastionaste la web. Ahora, sobre el papel, evalúa el apartado 6 de la plantilla: para cada ataque del jueves, ¿lo habría impedido alguno de los arreglos del 24?

- La inyección SQL: la consulta parametrizada la corta de raíz. Habría fallado.
- El IDOR: la comprobación de propietario devuelve 404. Habría fallado.
- La fuerza bruta: el límite de intentos la frena a los pocos intentos. Habría saltado antes y con menos ruido.
- La enumeración de usuarios: el mensaje único la deja sin información.

Pero fíjate en una cosa importante sobre la **contención** del día 18: cuando bloqueaste la IP del atacante en nginx, tus reglas de aplicación (1002xx) dejaron de verlo, porque sus peticiones ya no llegaban a la web; solo lo veía nginx. Es decir, contener en el borde **te quita visibilidad** del

atacante. Explica en tus lecciones aprendidas por qué eso puede ser un problema y cuándo compensa.

9. Escribe el informe (35 minutos)

Completa la plantilla entera y, al final, redacta el **resumen ejecutivo** (apartado 1): tres o cuatro líneas que entienda alguien que no es técnico (qué pasó, cuándo, qué se vio afectado y en qué estado queda). Es lo último que se escribe y lo primero que se lee.

10. Si algo no funciona

Tu Wazuh no arranca: es el plan B de la práctica del 11, apartado 11. Puedes hacer todo el análisis sobre un `alerts.json` de ejemplo si lo tuyo no levanta; pídemelo. Pero intenta levantarlo: `docker compose up -d` en `~/wazuh-docker/single-node` y espera un par de minutos.

No tienes alertas del 19 (no atacaste o se te borraron): genera el ataque hoy mismo. Desde tu Ubuntu, con la web arrancada, puedes relanzar el `ataque-simulado.sh` de la práctica del 18 contra `127.0.0.1:8080` (apunta la hora) y luego analizas eso. No es lo ideal (la IP será la local), pero sirve para toda la práctica.

`jq` se queja de una línea: `alerts.json` tiene una alerta por línea; si copiaste mal una receta, revisa las comillas. Prueba primero una receta tal cual está en `consultas-soc.md`.

No aparece `data.srcip` en algunas alertas: las de la aplicación traen la IP en `data.ip` (del JSON de miweb) y las de nginx en `data.srcip`. Por eso la receta usa `.data.srcip // .data.ip`. Apúntalo como un detalle de tus fuentes.

11. Preguntas

1. ¿Cuál fue la alerta más grave del incidente y por qué?
2. Pon un ejemplo de algo que hiciste el jueves y que tu SOC **no** detectó. ¿Por qué se le escapó?
3. ¿Por qué la hora del SOC y la de tu bitácora no coinciden, y cómo lo resuelves al montar la línea temporal?
4. De los arreglos del bastionado, ¿cuál habría cambiado más este incidente?
5. ¿Por qué bloquear al atacante en nginx puede dejarte "ciego" a lo que hace después?

12. Qué tienes que entregar (20 minutos)

Carpeta `NN-IC-caso` en ZIP con:

1. `plantilla-caso-soc.md` completa: resumen ejecutivo, línea temporal, tabla de cobertura, impacto, contención/erradicación y lecciones.
2. La salida de tus consultas `jq` (el perfil de reglas y la línea temporal).
3. Las respuestas a las preguntas del apartado 11.

No incluyas contraseñas ni hashes que aparezcan en las alertas: cita que estaban, no los copies.

13. Antes de entregar, comprueba que

1. La línea temporal cruza las horas del SOC (UTC) con las de tu bitácora (local).
2. La tabla de cobertura tiene una fila por cada prueba del jueves, con su alerta o la razón de que no la haya.
3. El resumen ejecutivo se entiende sin ser técnico.
4. Has razonado qué ataques habría parado el bastionado.

14. Seguridad

Trabajas sobre tus propios registros y tu propio incidente. En un SOC real, los datos de las alertas (IP, usuarios, rutas) son información sensible del cliente: se tratan con cuidado, no se copian fuera del caso y no se comparten. La misma disciplina de hoy.

Referencias

- Guía de gestión de incidentes del NIST (SP 800-61): https://csrc.nist.gov/pubs/sp/800/61/r3/final
- Wazuh, análisis de alertas: https://documentation.wazuh.com/current/user-manual/ruleset/index.html
- jq, manual: https://jqlang.github.io/jq/manual/